



ULTIMATE

Web3 Security Audit Dashboard

User Manual & Troubleshooting Guide

(Hinglish Edition — Hindi + English)

24+

Bounty Programs

10

Security Lenses

3

AI Models

3

Platforms

1	Introduction — S_A-H ULTIMATE kya hai?	3
2	Function Guide — Har Section ka Guide	4
2.1	Contest Radar — Live Bounty Data	4
2.2	AI Scanner — Human-AI Hybrid Engine	6
2.3	AI Security Tenses — PDE-Framework	6
2.4	Reports & Docs — PDF-Exhibits & Code	6
3	How to Work — Audit Start to Finish	8
4	Troubleshooting — Error Solving Guide	9
4.1	Git Clone Fail — GitHub Token Fix	9
4.2	Good Samaritan Nova Fail — AI Failback	10
4.3	APK Build Errors — Android Setup	11
5	Maintenance — API Keys Update Guide	11
6	Quick Reference — Cheat Sheet	12

S_A-H ULTIMATE (Security Audit Hub — Ultimate) ek advanced Web3 security audit dashboard hai jo specifically Indian blockchain security researchers ke liye banaya gaya hai. Yeh tool aapko smart contract vulnerabilities dhundhne mein, live bug bounty programs track karne mein, aur AI-powered security reports generate karne mein help karta hai.

"Ek tool jo aapka audit workflow professionally manage kare — from finding contests to generating PoC exploits."

🔍 Purpose / Uddeshy

- Smart Contract Code mein security vulnerabilities automatically detect karna
- Immunefi, HackenProof, aur Cantina se live bug bounty programs fetch karna
- AI (Groq, SambaNova, Gemini) se Proof-of-Concept exploit code generate karna
- Professional PDF audit reports export karna jo directly submit kar sako
- India-friendly KYC programs (Aadhaar, PAN, Passport) filter karna

📋 Key Features at a Glance

Feature	Description
Contest Radar	Live bounty programs Immunefi/HackenProof/Cantina se
AI Scanner	10 security lenses + 3 AI model fallback chain
PoC Generator	Groq !' SambaNova !' Gemini automatic fallback
PDF Export	Professional audit reports with findings & severity
GitHub Integration	Direct repo clone with auth token support
India KYC Filter	Aadhaar, PAN, Passport friendly programs first
APK Support	Capacitor-based Android app build support
Offline Mode	Curated data fallback when APIs unavailable

&🔧 Tech Stack (aapko pata hona chahiye):

- Frontend: React + Vite + TypeScript — modern web dashboard
- Backend: Express.js (Node.js) — API server port 8080
- AI Models: Groq (primary) !' SambaNova !' Gemini 2.5 Flash (fallback chain)
- Bounty Scraper: Live API + 10-min cache + curated fallback
- Mobile: Capacitor v8 — Android APK support

2.1 Contest Radar — Live Bounty Data

Contest Radar aapka main hunting ground hai. Yahan se aap live audit contests aur bug bounty programs dhundh sakte ho.

% Kaise Kaam Karta Hai (How it Works)

1. Jab aap Radar page open karte ho, dashboard API server se request bhejta hai
2. API server Immunefi, HackenProof, aur Cantina ke endpoints hit karta hai
3. Agar live data milta hai !' green 'Live API' badge show hoga top-right mein
4. Agar koi platform block karta hai !' amber 'Curated' badge aata hai (fallback)
5. Data 10 minutes ke liye cache hota hai — unnecessary API calls avoid karne ke liye

% Filters ka Use Kaise Karo

Filter Button	Kya Dikhta Hai
All	Sab platforms ke contests + bounty programs ek saath
Sherlock	Sirf Sherlock audit contest platform
Code4rena	Sirf Code4rena (C4) contests
Immunefi	Immunefi bug bounty programs only (\$10M MakerDAO tak)
HackenProof	HackenProof programs (1inch, NEAR Protocol, etc.)
Cantina	Cantina private/public contest programs
Active / Upcoming / Ended	Contest status se filter (sirf live contests ke liye)

Pro Tip:

Immunefi filter lagao aur max bounty dekho — \$10M+ programs pe focus karo. Unki scope files carefully padho.

India KYC:

Har program card pe 'India KYC' badge dikhega. Iska matlab us program mein Aadhaar/PAN/Passport se KYC ho sakti hai

% Scan This Repo Button

Kisi bhi contest card pe 'Scan This Repo' click karo — yeh automatically AI Scanner page pe redirect karega aur GitHub repo URL fill kar dega. Direct scanning shuru kar sakte ho!

2.2 AI Scanner — Human+AI Hybrid Engine

AI Scanner S_A-H ULTIMATE ka core feature hai. Yeh GitHub repositories ko automatically clone karta hai, Solidity/Rust/Vyper code analyze karta hai, aur AI se vulnerabilities detect karta hai.

%_ Human+AI Hybrid Approach kya hai?

Why 'Hybrid' Engine?

Pure AI scanning mein false positives zyada hote hain — AI kabhi kabhi galat vulnerabilities report karta hai. Human+AI Hybrid mein: AI 10 structured security lenses se code analyze karta hai (pre-defined patterns), phir human-readable findings generate karta hai jo aap verify kar sako before report submit karna. Result: Professional-grade findings with context — sirf noise nahi.

%_ Step-by-Step: Scanner Use Karna

1. GitHub repo URL copy karo (contest ka repo ya koi bhi public Solidity project)
2. AI Scanner page pe jao (left sidebar mein 'Scanner' click karo)
3. GitHub URL paste karo URL input field mein
4. Optional: apna GitHub Personal Access Token daalo (private repos ya rate limit ke liye)
5. 'Start Scan' button click karo — backend repo clone karta hai
6. Progress bar dikhega: Clone ! Parse ! Analyze (10 lenses) ! Generate Report
7. Scan complete hone ke baad Findings section mein results aayenge
8. Har finding pe click karo detail dekhne ke liye + AI-generated PoC code

%_ GitHub Token Kahan Se Milega?

```
# GitHub Personal Access Token banane ke steps:  
1. github.com ! Settings ! Developer settings  
2. Personal access tokens ! Tokens (classic) ! Generate new token  
3. Scopes: sirf 'repo' (read-only kafi hai public repos ke liye)  
4. Token copy karo — ek baar hi dikhta hai!  
5. Scanner mein GitHub Token field mein paste karo
```

& p Rate Limit Warning:

Bina token ke GitHub sirf 60 requests/hour allow karta hai. Token ke saath 5000/hour milta hai. Ek din mein zyada scan karna ho toh token zaroor daalo.

%_ AI Model Chain (Fallback System)

Scanner 3 AI models use karta hai — ek fail ho toh automatically next pe switch hota hai:

AI Model	Role
1st: Groq (LLaMA 3)	Primary model — fastest, best for code analysis
2nd: SambaNova	Fallback if Groq rate limited or API key missing
3rd: Gemini 2.5 Flash	Final fallback — Google ka powerful model
Unavailable	Agar teeno fail ho — manual analysis needed (rare)

2.3 10 Security Lenses — Kya Detect Karte Hain

S_A-H ULTIMATE ke scanner mein 10 specialized security lenses hain. Har lens ek specific vulnerability category pe focus karta hai.

01

Reentrancy Guard

External calls ke baad state changes — classic reentrancy attacks detect karta hai (jaise DAO hack)

02

Integer Overflow/Underflow

Unchecked arithmetic operations — SafeMath use hua ya nahi check karta hai

03

Access Control

onlyOwner, roles, modifiers — unauthorized function calls ki possibility check karta hai

04

Oracle Manipulation

Price feeds aur on-chain oracles — spot price manipulation aur flash loan attacks

05

Flash Loan Attack Vectors

Flash loan se ek transaction mein liquidity manipulation ki possibility

06

Front-Running / MEV

Transaction ordering dependence — sandwich attacks aur MEV extraction vectors

07

Signature Replay

EIP-712 signatures mein nonce/chainId check — replay attacks across chains

08

Logic Errors

Business logic bugs — protocol math, fee calculations, edge cases mein galat assumptions

09

Gas Griefing

Unbounded loops, DoS via gas exhaustion — griefing aur denial-of-service vectors

10

Upgrade Proxy Risks

Transparent/UUPS proxy patterns — storage collisions aur uninitialized proxies

🔴 Strategy:

Reentrancy (01) aur Access Control (03) pe pehle focus karo — yeh sabse common high/critical findings hain aur sabse zyada bounty pay karte hain

2.4 Reports & PoC — PDF Export & PoC Code

% Scan Report kaise Export karo

1. Scan complete hone ke baad Reports page pe jaao
2. Apna scan select karo list mein se
3. Top-right mein 'Export PDF' button click karo
4. PDF generate hogi — browser mein download prompt aayega
5. PDF mein hoga: findings list, severity breakdown, per-finding detail + PoC code

% PDF Report mein kya hota hai?

- Executive Summary: Total findings, Critical/High/Medium/Low count
- Per Finding Detail: Title, Description, Vulnerable Code Snippet, Impact
- PoC Code: AI-generated Foundry/Hardhat test case jo vulnerability demonstrate karta hai
- Remediation: Fix suggestion aur best practice reference
- Audit Metadata: Repo URL, scan date, lenses used, AI model used

% PoC Code ko kaise Use Karen

Generated PoC code Foundry test format mein hota hai. Yeh directly apne local environment mein run kar sakte ho:

```
# Prerequisites: Foundry install karo
curl -L https://foundry.paradigm.xyz | bash && foundryup

# PoC code copy karo PDF se ya dashboard se
# Naya test file banao:
touch test/SAH_PoC_Reentrancy.t.sol

# PoC code paste karo file mein, phir run karo:
forge test --match-test test_Reentrancy_PoC -vvvv

# Agar test fail karta hai = vulnerability REAL hai
# Agar test pass karta hai = false positive, discard karo
```

⚠ Before Submitting:

Hamesha PoC locally run karo verify karne ke liye. False positives submit karne se reputation kharab hoti hai aur duplicate reports mark ho jaate hain.

Report Submission Checklist:

- ' PoC code locally run karke verify kiya
- ' Duplicate check: platform pe similar report pehle se submit nahi hai
- ' Severity accurate hai (CVSS ya platform guidelines ke hisaab se)
- ' Impact clearly describe kiya — real-world scenario ke saath
- ' Remediation suggestion include kiya
- ' KYC documents ready hain (Aadhaar/PAN/Passport)

Yeh complete workflow hai ek professional Web3 security audit karne ka — S_A-H ULTIMATE use karke. Is process ko follow karo ek bhi step miss mat karo.

Phase 1: Target Selection (Contest Dhundho)

1. Contest Radar page kholo
2. Platform filter lagao — beginners ke liye Code4rena ya Sherlock best hain
3. Status filter: 'Active' select karo — sirf chal rahe contests dikhenge
4. Prize pool dekho: \$50K+ contests pe focus karo (competition zyada, but reward bhi zyada)
5. nSLOC (non-comment Source Lines of Code) dekho — 1000-5000 nSLOC ideal for beginners
6. Contest ka README padhne ke liye external link icon click karo
7. Scope files check karo: kaunse contracts in scope hain?

🔑 Beginner Tip:

Pehle ended contests dhundho aur unke reports padho (Sherlock ke reports public hote hain). Real findings ka pattern samjho pehle.

Phase 2: Reconnaissance (Repo Explore Karo)

1. 'Scan This Repo' click karo contest card pe — ya manually URL copy karo
2. AI Scanner mein GitHub URL paste karo
3. GitHub Token add karo (rate limiting avoid karne ke liye)
4. Scan shuru karne se pehle: GitHub pe repo kholo aur README padho
5. In-scope contracts list note karo (usually README ya scope.txt mein hoti hai)
6. Contest ka Discord/Telegram join karo — sponsors kabhi kabhi hints dete hain

Phase 3: Automated Scan (AI se Scan Karo)

1. 'Start Scan' click karo
2. Scan chal raha ho tab manually bhi code padho (parallel work karo)
3. Progress: Clone !' Parse !' 10 Lenses Apply !' AI Analysis !' Report
4. Scan complete hone ke baad findings list dekho
5. Severity ke hisaab se sort karo: Critical !' High !' Medium !' Low
6. Har finding ke liye 'View Details' click karo — full context padho

Phase 4: Manual Verification (Findings Verify Karo)

Yeh sabse important step hai — AI findings 100% accurate nahi hote:

1. Har High/Critical finding ke liye original code file kholo
2. AI ne jo vulnerable code bataya hai usse manually trace karo
3. Question: 'Kya yeh actually exploitable hai?'
4. PoC code local mein run karo (forge test command se)
5. Agar exploit kaam karta hai !' real finding hai, submit karo
6. Agar kaam nahi karta !' discard karo (false positive)
7. Medium findings ke liye: edge cases socho (special conditions mein trigger ho sakta hai?)

Phase 5: Report Submit Karo

1. PDF report export karo — yeh draft ke roop mein use karo
2. Platform ka official submission form kholo (Sherlock/C4/Immunefi)
3. Title likho: Clear aur specific (jaise 'Reentrancy in withdraw() allows drain of vault')
4. Severity select karo (platform guidelines follow karo strictly)
5. Impact explain karo: 'An attacker can...' format mein
6. PoC code paste karo (verified wala sirf)
7. Remediation suggest karo: 'Add nonReentrant modifier' jaisi specific fix
8. Submit! Platform usually 1-2 weeks mein respond karta hai

4.1 Git Clone Fail — GitHub Token Fix

Scan shuru karne ke baad agar 'Git clone failed' error aata hai, toh yeh common causes aur fixes hain:

%_ Diagnosis: Error Types

Error Message	Cause
Repository not found (404)	Repo private hai ya URL galat hai
rate limit exceeded (403)	GitHub API rate limit hit ho gaya (60/hr without token)
Authentication failed	Token expired ya galat scope set kiya
timeout / connection refused	Network issue ya GitHub down (rare)
Permission denied (publickey)	SSH URL use ki instead of HTTPS

%_ Fix Steps

1. GitHub URL verify karo: `https://github.com/username/repo` format hona chahiye (SSH URL mat use karo)
2. Repo access check karo: browser mein URL kholo — 404 aata hai toh repo private/deleted hai
3. GitHub Token generate karo (agar nahi kiya): github.com !' Settings !' Developer settings !' PAT
4. Token scope: 'repo' permission select karo (read access kafi hai)
5. Scanner ke GitHub Token field mein token paste karo
6. Dobara scan shuru karo — ab kaam karna chahiye

```
# Token test karne ka quick way (terminal mein):
curl -H 'Authorization: token YOUR_TOKEN_HERE' https://api.github.com/rate_limit

# Expected output mein ye dikhna chahiye:
# 'limit': 5000
# 'remaining': 4999 (ya koi bhi number > 0)

# Agar 401 error aaye: token galat hai, regenerate karo
# Agar 403 aaye: token ka scope galat hai (repo permission chahiye)
```

& p Important:

GitHub Token ko secret rakho — kisi ke saath share mat karo. Agar share ho gaya toh immediately revoke karo: GitHub !' Settings !' Developer Settings !' Delete Token

4.2 Groq / SambaNova Fail — AI Fallback Explanation

AI Scanner ek 3-tier fallback chain use karta hai. Agar ek fail ho toh automatically next pe switch hota hai:

Groq (Primary)	!' SambaNova (Fallback 1)	!' Gemini 2.5 Flash (Fallback 2)
!" fail	!" fail	!" fail
Rate limit?	API key missing?	Check internet
Key expired?	Account suspended?	!' Contact support

% API Key Errors aur Fix

Error	Meaning
Groq: invalid_api_key	GROQ_API_KEY env variable set nahi hai ya galat hai
Groq: rate_limit_exceeded	Free tier limit hit — SambaNova pe auto-fallback hoga
SambaNova: 401 Unauthorized	SAMBANOVA_API_KEY missing ya expired
Gemini: API_KEY_INVALID	GEMINI_API_KEY ya VITE_GEMINI_API_KEY set nahi
pocSource: unavailable	Teeno models fail ho gaye — check all 3 keys

% API Keys Set Karne Ka Tarika

1. Replit project mein jaao !' left sidebar mein 'Secrets' icon click karo (lock icon)
2. New Secret add karo:
3. GROQ_API_KEY — groq.com se free account banao, API key copy karo
4. SAMBANOVA_API_KEY — sambanova.ai se key lo
5. GEMINI_API_KEY — aistudio.google.com se free Gemini key lo
6. Keys save karo — workflow automatically restart karega
7. Scanner dobara use karo — ab teeno models available honge

Ø=Ü; Free Keys:

Groq aur Gemini dono free tier ke saath kafi generous hain daily limits ke liye. SambaNova bhi free tier provide karta hai. Teeno set karo guarantee ke live ki koi na koi kaam kare.

4.3 APK Build Errors — Android Setup Guide

S_A-H ULTIMATE ko Android APK ke roop mein build kar sakte ho Capacitor v8 ke through. Yeh Replit pe directly nahi ho sakta — local machine pe karo.

% Prerequisites (Pehle yeh install karo)

- Node.js 18+ (node --version se check karo)
- Android Studio (developer.android.com/studio se download karo)
- Android SDK — Android Studio ke through install hota hai automatically
- Java JDK 17+ (Android Studio ke saath usually aata hai)
- pnpm (npm install -g pnpm)

% Common APK Build Errors aur Fix

Error	Fix
ANDROID_HOME not set	Android SDK path environment variable set karo
SDK location not found	local.properties file mein sdk.dir set karo
Gradle build failed: license	Android Studio kholo !' SDK Manager !' Accept licenses
Could not resolve dependencies	Internet check karo, proxy settings clear karo
BUILD FAILED: compileSdkVersion	Android Studio mein SDK 34+ install karo
capacitor.config.json not found	artifacts/audit-dashboard/ se cap commands run karo
webDir 'dist/public' not found	Pehle pnpm build run karo, phir cap sync karo

```
# Android Studio install karne ke baad:
export ANDROID_HOME=$HOME/Library/Android/sdk # macOS
export ANDROID_HOME=$HOME/Android/Sdk         # Linux
export PATH=$PATH:$ANDROID_HOME/tools:$ANDROID_HOME/platform-tools

# Project root se build commands:
pnpm --filter @workspace/audit-dashboard run build
cd artifacts/audit-dashboard
npx cap sync android
cd android && ./gradlew assembleDebug

# APK location:
android/app/build/outputs/apk/debug/app-debug.apk
```

🔍 Quick Test:

APK install karne se pehle: adb install app-debug.apk se directly connected phone pe test karo. Sahi kaam kar raha hai toh release build banao



API keys occasionally expire hoti hain ya limits hit ho jaati hain. Neeche complete guide hai future mein keys update karne ka:

% **Replit Environment Mein Keys Update Karna**

1. [replit.com](#) pe apna project kholo
2. Left sidebar mein lock icon (🔒 Secrets) click karo
3. Jo key update karni hai usse dhundho list mein
4. Edit icon click karo !' naya value paste karo
5. Save karo — API server automatically restart hoga
6. Dashboard mein scanner test karo confirm karne ke liye

% **Kahan Se Free API Keys Milte Hain**

Service	Kahan Jaana Hai
Groq (GROQ_API_KEY)	console.groq.com !' API Keys !' Create
SambaNova (SAMBANOVA_API_KEY)	cloud.sambanova.ai !' API !' Generate Key
Gemini (GEMINI_API_KEY)	aistudio.google.com !' Get API Key !' Free tier
GitHub (GITHUB_TOKEN)	github.com !' Settings !' Developer Settings !' PAT

% **Key Expiry ke Signs**

- Scanner mein 'AI unavailable' ya 'pocSource: unavailable' dikhne lagta hai
- All scans pe error aane lagte hain — no findings generated
- API server logs mein 401/403 errors dikhte hain
- GitHub rate limit bar continuously red/amber dikhta hai

Regular Maintenance Schedule

Frequency	Action
Monthly	Groq aur SambaNova key rotation (security best practice)
Every 3 months	GitHub PAT renewal (token expiry avoid karne ke liye)
When needed	Gemini key — usually nahi expire hoti, but check karo agar issues hon
After any breach	Immediately revoke ALL keys aur regenerate karo

🔒 Security Best Practices for API Keys:

- Keys ko kabhi code mein directly nahi likhte — hamesha Secrets/env vars use karo
- Keys kisi ke saath share mat karo — ek key = ek user
- Agar key accidentally git mein commit ho jaaye: turant revoke karo, git history clean karo
- Groq/SambaNova keys mein IP allowlist lagao agar option ho
- Monthly ek bar dashboard kholo aur scanner test karo — ensure everything works



Action	What Happens
Dashboard Load !' Radar	Pehla page — live bounty programs
Radar !' Immunefi filter	India-friendly max-bounty programs
Radar !' Contest card !' 'Scan This Repo'	Direct scanner launch with URL prefilled
Scanner !' GitHub URL + Token !' Start Scan	Full automated scan launch
Findings !' Click any finding	Detail + PoC code view
Reports !' Export PDF	Professional PDF report download
About page	App version, API status, model status

Severity Classification Guide

Severity Level	Examples
Critical (9-10 CVSS)	Direct fund loss, unauthorized mint/burn, full protocol drain
High (7-8 CVSS)	Significant fund loss possible, major access control bypass
Medium (4-6 CVSS)	Limited fund loss, temporary DoS, logic errors with conditions
Low (1-3 CVSS)	No fund loss, informational, best practice violations
Informational (0)	Code quality, gas optimization, style issues

Emergency Quick Fixes

Problem	Quick Fix
'Cannot connect to API'	Browser refresh karo !' agar persist: workflow restart karo
'Git clone failed'	GitHub token add karo (4.1 section dekho)
'AI unavailable'	API keys check karo (4.2 section dekho)
'No programs found' in Radar	Internet check karo — curated fallback normally handle karta hai
APK build fails	Android Studio SDK licenses accept karo (4.3 section dekho)
PDF export not working	Browser popup blocker disable karo for this site
Scanner stuck at 0%	Network tab check karo — API server running hai?

Bounty Platform Comparison

Platform	Details
Immunefi	\$1K–\$10M, DeFi focus, best payouts, strict KYC
HackenProof	\$500–\$1M, CeFi+DeFi, faster response, Aadhaar OK
Cantina	\$5K–\$2M, invite-based contests, quality > quantity
Sherlock (via Radar)	Contest format, \$10K–\$500K, community judging
Code4rena (via Radar)	Contest format, \$5K–\$1M, automated + manual judging

Ø<B/E Final Advice:

Consistency beats everything. Ek contest pe weekly 10 ghante dene wala researcher consistently better results leta hai compared to occasional 40-hour sprint. S. A-H ULTIMATE aanka daily workflow tool hai

S_A-H ULTIMATE

Web3 Security Audit Dashboard

Version 3.0 — User Manual Complete

Agar koi problem ho toh:

1. Is manual ka relevant section dobara padho
2. API server logs check karo
3. API keys verify karo (Section 5 dekho)
4. Dashboard refresh karo

© 2025 S_A-H Security — Built with 'dp' for Indian Web3 Researchers